

Table of Contents

ANNEX D: COMPLIANCE, CONTROLS & AUDIT FRAMEWORK

Zarewa Aluminium and Plastics Ltd — System of Operations v3.0

Audience: Internal audit, finance, MD, external auditors

D.1 INTERNAL CONTROL FRAMEWORK

Zarewa ERP implements a three-layer control model:

Layer	Mechanism	Examples
Preventive	Blocks invalid action before it occurs	Period lock, duplicate receipt block, refund self-approval block
Detective	Alerts and reports after event	Governance pack, exception queue, dual-control warnings
Corrective	Reversal and adjustment workflows	Receipt reversal, material incident void, edit approval

D.2 SEGREGATION OF DUTIES MATRIX (COMPLETE)

Process	Initiate	Approve	Execute	Record	Reconcile
Customer sale	Sales	BM (clearance)	Operations (delivery)	System auto	Finance (AR)
Customer receipt	Sales/ Cashier	Cashier (clearance)	Cashier (post)	System auto	Finance (bank rec)
Customer refund	Sales	BM/MD/ Finance	Cashier/ Finance	System auto	Finance
Expense payment	Staff	BM/MD	Cashier/ Finance	System auto	Finance
Purchase order	Procurement/MD	MD	—	System	Finance (AP)
Goods receipt	Operations	—	Operations	System auto	Store (stock register)
Supplier payment	Finance	Finance	Finance	System auto	Finance (AP rec)
Production	Operations	BM (QC)	Operations	System	Finance (AP1c)

job				auto	
Payroll	HR Admin	GMHR + MD	Finance	System auto	Finance
GL journal	Finance	—	Finance	Finance	Finance (TB)
Period close	—	—	Finance	Finance	MD review
User creation	Admin	MD policy	Admin	System auto	Admin audit
Price list change	MD	—	MD	System auto	Sales review
Material incident	Operations	BM	System auto-post	System	Store

D.3 FINANCIAL CONTROLS DETAIL

D.3.1 Revenue Recognition Control (AP1c)

Risk: Revenue recognised before production or after cash only.

Control: AP1c auto-posts at production job completion only.

Test: Select completed jobs; verify GL Cr 4000 matches produced metres × price.

Frequency: Monthly.

D.3.2 Cash Receipt Control

Risk: Fictitious receipts inflate sales.

Control: Cashier clearance required; amounts ≥ ₦100k double-entered.

Test: Sample 25 receipts; trace to bank statement.

Frequency: Weekly.

D.3.3 Refund Control

Risk: Fraudulent refunds to colluding parties.

Control: Requester ≠ approver ≠ payer; MD gate > ₦1M; production alignment check.

Test: All refunds > ₦500k monthly; verify evidence on file.

Frequency: Monthly.

D.3.4 Procurement Control

Risk: Kickbacks, unauthorised purchases.

Control: MD approval on POs; three-way match at month-end.

Test: Sample 10 POs; trace PO → GRN → payment.

Frequency: Monthly.

D.3.5 Inventory Control

Risk: Coil theft, unrecorded usage.

Control: Coil control events immutable; stock register 4-stage sign-off.

Test: Physical coil count vs system for 5 random lots.
Frequency: Monthly (at stock register).

D.4 HR AND PAYROLL CONTROLS

D.4.1 Ghost Employee Risk

Control: Payroll run requires active HR profile; exit clearance blocks deactivation bypass.
Test: Reconcile payroll headcount to HR active staff report.

D.4.2 Unauthorized Salary Change

Control: Salary matrix changes require salary_structure.approve (MD).
Test: Review all salary changes in period against approved requests.

D.4.3 Loan Fraud

Control: Loan approval chain; obligation account tracks balance; payroll deduction auto-calculated.
Test: OBL balances agree to loan agreements on file.

D.5 AUDIT LOG REVIEW PROCEDURES

D.5.1 Daily Review (IT Admin)

Query audit_log for: - login.failed — brute force attempts - permission.override — custom permission changes - admin.data_reset — must be empty in production - refund.dual_control.admin_trial — admin bypass flags

D.5.2 Weekly Review (Finance Manager)

- Receipt reversals
- Refund approvals and payouts
- Period lock attempts
- Treasury corrections

D.5.3 Monthly Review (MD + Internal Audit)

- Governance pack export
- All refunds > ₦1,000,000
- Others expense category > 15% branches
- Dual-control warnings
- Edit approval usage

D.5.4 Audit Log Export

GET /api/audit/export.ndjson — admin only; full export for external auditor.

D.6 REGULATORY COMPLIANCE

D.6.1 PAYE and Tax

- Payroll computes PAYE per staff per Nigerian tax bands
- Export from HR payroll module for FIRS filing
- Finance retains payslips and tax schedules 6 years

D.6.2 Pension (PENCOM)

- Employer and employee contributions calculated per statute
- GL posts to 2400 Pension Payable (liability)
- Monthly remittance schedule exported with payroll

D.6.3 Data Protection

- Staff personal data in hr_staff_profiles — access restricted by HR permissions
 - Bank details encrypted at rest (hrBankCrypto.js)
 - Confidential work items restricted to participants
 - Staff files retained 7 years post-separation; then secure destruction per policy
-

D.7 FRAUD INDICATORS AND RESPONSE

Indicator	Investigation Step
Multiple refunds to same customer in 30 days	Review lifecycle timeline; interview sales officer
Receipts cleared without matching bank credit	Bank rec investigation; cashier interview
Production metres consistently High conversion	QC review; possible metre inflation
Others expenses spike at branch	BM coaching; MD review
Same user login from two IPs simultaneously	Session security review; password reset
Coil qty drops without production job	Material incident search; CCTV if available
Payroll line for separated employee	Exit clearance audit

Response: Suspend ERP access pending investigation (Admin); preserve audit logs; escalate to MD; law enforcement if criminal.

D.8 EXTERNAL AUDIT PREPARATION

Documents to Prepare

Package

Trial balance
GL activity by account
Receipts register
Purchase register
Stock register (locked)
Payroll summary + MD sign-off
Bank reconciliation
Governance pack
Audit log export
Related party transactions

Auditor System Access

Provide viewer role or read-only custom role with reports.view — never admin credentials.

D.9 CONTROL DEFICIENCY REPORTING

Staff who identify control weaknesses:

1. Report to line manager and Finance Manager (if financial)
 2. Do not exploit weakness
 3. IT logs remediation ticket
 4. MD notified if material
 5. Fix verified in next audit cycle
-

D.10 BOARD REPORTING (QUARTERLY)

MD presents to Board from Command Centre:

- Branch scorecard vs targets
- Governance pack summary
- Material incidents and discipline summary
- Stock register status all branches
- AP1c/AP2/AP3 readiness
- IT incident summary
- Fraud indicators (if any)

End of Annex D — Compliance & Audit Framework